

Security Barrier

사내 보안자료 유입 대응 스킴 — 설계 및 사전조사

설계 문서 · 2026-09-13 · eunha9348/Security-Barrier

이 문서의 검증 상태

이 문서는 “확인하지 않은 것을 쓰지 않는다”를 최우선 규칙으로 작성했다. 각 주장의 근거 등급은 아래와 같다.

등급	의미	이 문서에서의 표기
1차 확인	공식 문서를 직접 열람해 확인	근거 URL 명시
2차 확인	검색 결과 메타데이터·요약으로 확인. 원문 전체는 미열람	논문 제목·ID·수치는 이 등급. 인용 전 원문 확인 필요
미확인	확인하지 못함	본문에 “확인되지 않음”으로 명시

이 문서가 단정하지 않는 것

본 설계는 모델 가중치와 제공자 서버측 로그에 대해 어떠한 통제력도 주장하지 않는다. 논문에서 인용한 수치는 해당 논문의 보고값이며 본 프로젝트가 재현한 결과가 아니다. 아래 4절의 아키텍처는 아직 구현·검증되지 않은 **설계안**이다.

01

배경과 목표

사내 보안 문서가 AI로 흘러 들어가지 않도록 막고, 만약 들어갔다면 유입된 흔적을 역추적·정추적해 모두 삭제하는 Claude Code 스킬을 만든다. /security-barrier 로 호출한다.

설계상 지켜야 할 두 가지 원칙

- 1차 판단은 회사가 관리하는 **보안 Axis**를 기준으로 한다. 인가된 사용자만 수정할 수 있다.
- 전 과정에서 **Hallucination**이 발생하면 안 된다. 이 요구가 설계 전반을 규정한다.

두 번째 원칙이 설계를 바꾼 지점

“검증할 수 없는 것은 보고하지 않는다”를 규칙이 아니라 구조로 강제해야 한다. 프롬프트에 “추측하지 마라”라고 적는 것으로는 부족하다. 이 문서의 3절·4절·5절은 모두 이 요구에서 파생된 결론이다.

02

중복 조사 — 이미 있는 스킬인가

Claude Skill 마켓플레이스 4곳, GitHub 큐레이션 목록, 상용 AI-DLP 제품, arXiv 논문을 조사했다. 동일한 스킬은 존재하지 않는다. 다만 기능을 4개 층위로 나누면 3개는 이미 포화 상태다.

층위	내용	판정	겹치는 것
A	사전 차단 (입력 DLP)	심각한 중복	상용: Nightfall, Prompt Security, Lasso, Microsoft Purview DLP for Copilot, Strac·dope·Aona(“Claude DLP”로 판매 중) 스킬: Cloud DLP, sanitize, ironclaw-agent-guard, varlock, shellward
B	정책 기반 1차 판단 (= 보안 Axis)	개념 중복	policy-opa 스킬, rego-skill, Purview 민감도 레이블. 단 “인가자만 수정 가능한 불변 서명 정책축”으로 패키징된 사례는 찾지 못함
C	유입 후 양방향 추적 + 파생물 전파 삭제	빈 공간	연구는 활발하나 에이전트 스킬로 구현된 사례 없음
D	LLM 자체 망각	구현 불가	가중치 접근 필요. 3절 참조

C가 비어 있는 이유

원본 문서를 지워도 그것이 낳은 청크·임베딩·요약·캐시된 답변·리랭커 입력은 지워지지 않는다. 삭제는 모든 파생 아티팩트로 전파되어야 하며, 각 파생물은 원본으로 되돌아가는 안정적 참조를 들고 있어야 한다. SIGIR 2026 논문의 제목이 그대로 “Deletion Isn’t Enough” 다.

“Reverse / Forward Tracing 병렬 수행”이라는 발상 자체는 새롭지 않다. 데이터 거버넌스의 **backward lineage**(근본원인 분석·사고 대응)와 **forward lineage**(영향 분석)가 이미 확립된 개념이다. 새로운 것은 알고리즘이 아니라 **적용 대상**이다 — 에이전트 워크스페이스.

그래서 진짜 새로운 것

- ① 에이전트 워크스페이스(세션 전사, CLAUDE.md, 메모리 파일, 톨 로그, 캐시, git 히스토리, 생성 산출물)를 한 단위로 묶어 양방향 추적 후 폐기하는 스킴
- ② 에이전트가 읽되 수정할 수 없는 서명된 정책축
- ③ 결정론 1차 / LLM 2차 라는 2단 판정 + 판정 보류(abstain) 강제
- ④ “지웠다”가 아니라 “지웠음을 증명한다”로 출력을 정의

03

기술적 제약 — 무엇이 가능하고 무엇이 불가능한가

“LLM이 자체 폐기하고 그 문서를 잊도록 한다”는 요구는 스킴 레이어에서 구현할 수 없다. 이 문장을 그대로 구현하면 스킴이 검증 불가능한 주장을 하게 된다. 근거는 아래와 같다.

제약	내용	근거 등급
컨텍스트는 append-only	이미 모델에 들어간 토큰을 소급해 “안 본 것”으로 만들 수 없다. 가능한 것은 세션 폐기, 서버측 컨텍스트 편집(clear_tool_uses)으로 이후 턴에서 제외, 로컬 아티팩트 삭제뿐이다.	1차 확인
샘플링 조작 경로가 닫혀 있음	Claude Opus 4.6 이후 모델은 temperature:top_p·top_k 지정을 거부한다(기본값 외 400). logit_bias는 Messages API 문서에서 확인되지 않았다 (“존재하지 않음”을 확인한 것이 아니라 기재를 찾지 못함).	1차 확인 (logit_bias는 미확인)
제공자 측 보존은 범위 밖	프롬프트가 트레이싱 백엔드에 들어갔다면 그 시스템의 보존정책·접근제어·익스포트 연동을 따른다. 계약(ZDR) 영역이다.	2차 확인
크리덴셜은 되돌릴 수 없음	모델을 통과한 크리덴셜은 회전은 되지만 사본은 회전되지 않는다. 정답은 삭제가 아니라 노출 가정 + 회전/권한회수 다.	2차 확인
망각은 검증 자체가 미해결	(ε,δ)-인증은 “잊었다”를 직접 검증하지 않고 참조 모델과의 구분불가능성만 정량화한다. 기존 검증 스킴은 보조 계측에 의존하거나 파이프라인 변경에 취약해 스푸핑이 쉽다.	2차 확인

반대로, 스킴이 실제로 할 수 있는 것

- 세션 폐기 및 컨텍스트에서의 실제 제거
- 로컬 아티팩트(전사·로그·메모리 파일·git 히스토리) 삭제와 **삭제 검증**
- 자격증명 회전 지시
- 폐기 증적(tombstone·해시·재검증 결과) 산출

결론: 스킴 이름을 바꿔야 한다

“unlearning / 망각”이 아니라 **Containment & Verified Purge**로 재정의한다. 그렇게 하지 않으면 위 제약 때문에 스킴이 구조적으로 거짓 보고를 하게 된다.

04

Hallucination 방지 규칙 (R1-R6)

3절의 제약에서 직접 파생된 강제 조항이다. 각 규칙은 프롬프트 문구가 아니라 가능한 한 **코드와 구조**로 강제되어야 한다.

	규칙	내용
R1	1차 판단은 결론론적으로	Axis 매칭은 정규식·해시·라벨·경로 규칙으로 수행한다. LLM은 1차 판단에 관여 금지. LLM은 결론론적으로 걸린 후보에 대한 2차 문맥 판단만 한다.
R2	증거 없으면 판정 보류	파일 경로·라인 번호·해시 같은 인용 가능한 증거 없이는 “유출됨”도 “삭제됨”도 단정 금지. 출력 스키마에 UNVERIFIED 상태 필수.
R3	삭제는 검증으로 닫는다	삭제 후 동일 탐지기를 재실행해 0건 확인 + 삭제 전후 해시 기록. 검증 실패 시 “삭제됨” 보고 금지.
R4	“있었다”고 말하지 않는다	보고서는 “모델 망각” 대신 컨텍스트 격리 / 아티팩트 폐기 / 자격증명 회전 필요 로만 표현. 모델 가중치·제공자 로그는 범위 밖으로 명시.
R5	Axis는 불변 입력	정책 파일은 읽기 전용 + 서명(GPG/sigstore) + CODEOWNERS. 에이전트가 Axis를 수정하는 경로 자체를 차단.
R6	미도달 범위 명시	리포트 말미에 추적 불가 영역 (제공자 서버 로그, 타인 세션, 이미 전송된 외부 SaaS)을 항상 열거. 조용히 생략하면 그것이 곧 hallucination이다.

05

기각된 안 — Dummy data 희석

“삭제가 불가능하다면 해당 자료의 가중치를 최하로 낮추고 dummy data로 희석하면 어떨까”라는 제안을 검토하고 기각했다.

(a) “가중치 최하” — 조작할 핸들이 없다

- 스킬은 어텐션 가중치에 접근할 인터페이스가 없다.
- 샘플링 파라미터 경로는 3절대로 닫혀 있다.
- “이 내용은 무시하라”는 지시는 내용을 컨텍스트에 **유지한 채** 주의만 환기시킨다. 제거가 아니라 강조에 가깝다.
- 실재하는 유일한 “가중치 낮추기”는 컨텍스트에서 실제로 빼는 것이며, 그것은 희석이 아니라 삭제다.

(b) 희석 — 정보를 제거하지 않고 추가할 뿐이다

#	기각 사유
1	정보이론적으로 무효. 희석은 진짜 데이터의 정보량을 줄이지 않는다. 총량만 늘린다. 원본은 여전히 컨텍스트·전사·로그에 완전한 형태로 존재한다.
2	외부 오라클로 즉시 분리된다. 크리덴셜은 사용해 보면 되고 문서는 원본과 대조하면 된다. 더미를 진짜와 구분 불가능하게 만드는 문제(flatness)는 honeywords(Juels & Rivest, CCS 2013)가 10년 넘게 풀지 못해 주요 인증 플랫폼에 채택되지 못한 바로 그 문제다.
3	실증 반례가 있다. arXiv:2609.04382 — 실제 행과 디코이를 섞었으나 손실이 디코이를 무시해 그래디언트가 정확히 0이 되었고, 그 0의 패턴만으로 실제 행이 전부 식별되었다. 논문 보고값 기준 9개 시드에서 프레임당 4,096/4,096 전량 적중.
4	노이즈는 복원된다. 단어 단위 DP 새니타이즈조차 주변 문맥으로 원문 재구성이 가능하다 (arXiv:2508.18976). 희석은 DP보다 약한 보장이다.
5	확률적 저하는 통제가 아니다. 디스트랙터가 검색 성능을 떨어뜨린다는 결과는 있으나, 평균 정확도 하락이지 접근 차단이 아니다.
6	자기 파괴적이다. 자사 DLP 스캐너·시크릿 스캐너·감사 로그가 오염된다. 경보 피로로 진짜 사고의 탐지율이 떨어진다.
7	정당 사용자의 효용도 붕괴한다. 모델이 진짜와 더미를 구분하지 못해 업무 질의에도 잘못된 값을 반환한다.

기각 사유

- 8 검증이 불가능하다 — R2/R3 위반. “희석되었다”를 입증할 메트릭이 없다. 증거 없이 완화를 보고하는 순간 그것이 이 프로젝트가 금지한 hallucination이다.

06

채택한 대안

대안 1 — 출력측 교정 (CURE 방식)

arXiv:2509.25973 — Corrective Unlearning with Retrieved Exclusions. 경량 corrector가 출력에 누출이 있는지 검증하고, 있으면 재작성한다. 제외 대상을 검색해 in-context 레퍼런스로 제공하므로 **추가 학습 없이** 신규 요청에 적응하며, 연속 언러닝 요청에 강건하고 간접 질의 누출까지 줄인다고 보고한다.

보강 근거 — arXiv:2403.03329 (Guardrail Baselines for Unlearning in LLMs, Thaker et al., 2024-03): 프롬프트·입력필터·출력필터 같은 단순 가드레일이 파인튜닝 언러닝과 대등한 성능을 낸다고 보고한다. 즉 가중치를 건드리지 않아도 된다.

희석과의 결정적 차이

희석은 은폐를 시도하고, CURE는 **출력 경로를 차단**한다. 후자는 검증 가능하다. 단 CURE도 100%가 아니므로 결과는 “차단”이 아니라 “완화”로만 보고해야 한다(R4).

대안 2 — Dummy를 은폐가 아니라 탐지에 사용 (Canary / Honeypot)

발상의 방향만 뒤집는다. 가짜 보안문서·가짜 크리덴셜을 Axis에 카나리로 등록해 심어두고, 그것이 모델 출력이나 외부 채널에 나타나면 **유출 확정 신호**로 쓴다. 심은 곳 외에는 존재할 수 없는 문자열이므로 구조적으로 오탐이 0이다. 직접 유사도 탐지가 실패하는 패러프레이즈·번역·부분 추출 상황에서도 동작한다.

한계: 카나리가 변형되어 유출되면 매칭이 실패할 수 있다. 이 한계는 리포트에 명시한다.

07

확정 아키텍처

아직 구현되지 않은 설계안이다.

```
[Security Axis]  서명 + 읽기전용 + CODEOWNERS. 인가자만 수정
|
+-- GATE         사전 차단 (총위 A. 기존 스킴과 중복 → 최소 흑만)
|
+-- BREACH       유입 감지 시
|               |
|               +-- REVERSE TRACE  어디서 들어왔나  \
|               |                                     > 병렬
|               +-- FORWARD TRACE  무엇을 냈었나   /
|               |
|               +-- PURGE          파생물 먼저 → 원본. tombstone 기록
|               +-- SUPPRESS      CURE식 출력 corrector. "완화"로만 보고
|               +-- VERIFY        동일 탐지기 재실행 0건 + 해시 대조
|               +-- ROTATE        크리덴셜은 삭제 불가 전제 → 회전 지시
|               +-- REPORT        도달 불가 영역 항상 명시
```

단계별 출력 상태값

상태	의미
PURGED_VERIFIED	삭제 후 재탐지 0건 + 해시 대조 통과. 이것만이 “삭제됨”이다
PURGE_FAILED	삭제를 시도했으나 재탐지에서 잔존 확인
UNVERIFIED	증거 부족으로 판정 불가. 추측으로 채우지 않는다
ROTATION_REQUIRED	크리덴셜. 삭제로 해결되지 않음
UNREACHABLE	이 스킬의 도달 범위 밖

이 5개 외의 상태값을 만들지 않는다. “아마 삭제됨”, “대부분 처리됨” 같은 값은 금지한다.

08

스킬 구현 메커니즘

공식 문서(code.claude.com/docs/en/skills)로 확인한 내용이다. 스킬은 파일 하나가 아니라 디렉터리이며, 실행 스크립트를 번들할 수 있다. 이것이 R1(결정론적 1차 판정)을 구조적으로 강제 가능하게 만든다.

```
.claude/skills/security-barrier/
  SKILL.md                (필수)
  axis/security-axis.yaml  정책축. 서명 + 읽기전용
  scripts/classify.py      1차 판정 — LLM 호출 없음
  scripts/trace.py         역추적 / 정추적
  scripts/purge.py         파생물 → 원본 폐기, tombstone
  scripts/verify.py        재탐지 + 해시 대조
  scripts/canary.py        카나리 등록 · 탐지
  references/report-schema.md
```

핵심 — 실행 결과의 사전 주입

공식 문서 인용: “The !`<command>` syntax runs shell commands **before the skill content is sent to Claude**. The command output replaces the placeholder, so Claude receives actual data, not the command itself.”

이것이 R1을 구조로 바꾼다

스크립트가 먼저 돌고, 그 출력이 데이터로 치환된 채 모델에 도착한다. 모델은 1차 판정에 개입할 기회 자체가 없다. “LLM은 1차 판단 금지”를 프롬프트 규율이 아니라 구조로 강제할 수 있다는 뜻이며, Hallucination 방지 관점에서 이 설계의 가장 중요한 수확이다.

이 프로젝트에서 쓸 프론트매터

필드	용도
allowed-tools	scripts/ 하위 실행 사전 승인 (권한 프롬프트 제거)
disallowed-tools	폐기 중 외부 전송 계열 툴 제거 — 2차 유출 차단
hooks	스킬 실행 시 혹은 등록. 폐기 후 해당 경로 재접근을 세션 내내 차단
context: fork + agent	추적을 서브에이전트에서 수행 → 보안 내용이 메인 세션 컨텍스트에 미유입. 한계: 서브에이전트 전사도 결국 전사다. 확산 범위를 줄이는 것이지 없애는 것이 아니다.

필드	용도
background: false	fork 결과를 기다림
disable-model-invocation	/security-barrier 로만 호출할지, 자동 발동도 허용할지
paths	특정 그룹에서만 활성화

변수: `${CLAUDE_SKILL_DIR}`, `${CLAUDE_PROJECT_DIR}`, `${CLAUDE_SESSION_ID}` — 경로 참조에 사용. 호출은 자동(description 매칭) 또는 `/skill-name` 직접 호출.

배포 형태

혹은 원래 settings.json 영역이라 스킬과 분리되어 있으나, **플러그인은** skills·hooks·commands·agents·MCP를 한 단위로 묶어 배포한다. 사내 전체 배포의 최종 형태는 플러그인이 적합하다. 스킬로 먼저 만들고 나중에 감싸면 된다. (2차 확인 — 매니페스트 규격은 공식 문서로 재확인 필요)

스크립트를 번들해도 바뀌지 않는 것

스크립트는 **로컬 머신에서만** 실행된다. 층위 A·B·C는 전부 구현 가능해지지만, 층위 D(모델 가중치, 제공자 서버 로그)에는 번들 스크립트도 닿지 않는다. 3절의 결론은 그대로 유효하다.

09

관련 논문

모든 항목은 2차 확인 등급이다 — 제목·ID·저자·보고 수치는 검색 결과로 확인했으나 원문 전체를 읽고 검증하지는 않았다. 인용 전 원문 확인이 필요하다. arXiv ID가 26xx인 것은 2026년 발표분이다.

9.1 우선 읽을 4편

ID	제목	이 프로젝트에서의 용도
2505.23643	Securing AI Agents with Information-Flow Control (FIDES) — Microsoft, 코드 github.com/microsoft/fides	기밀성·무결성 라벨을 메시지·액션·툴호출·결과에 전파하고 정책 만족 시에만 실행. Security Axis 설계의 가장 직접적인 참조 구현
2605.14421	MemLineage: Lineage-Guided Enforcement for LLM Agent Memory	가장 가까운 선행. 비파괴 삭제 + tombstone (원본 id + 삭제 사유)으로 포함 증명 유지. PURGE 단계에 차용
2604.23374	Ghost in the Agent: Redefining Information Flow Tracking for LLM Agents (NeuroTaint)	taint 전파를 명시적 전달뿐 아니라 의미 변형·결정에 대한 인과 영향·세션 간 메모리 지속까지 확장. FORWARD TRACE 개념과 거의 일치
2604.21308	CI-Work: Benchmarking Contextual Integrity in Enterprise LLM Agents	기업 워크플로 전용. 논문 보고값: 위반율 15.8-50.9%, 유출 최대 26.7%. 효용이 높을수록 프라이버시 위반이 증가하는 트레이드오프 — 이 스킬의 존재 이유

9.2 망각 — 기본기 / 벤치마크

ID	제목	이 프로젝트에서의 용도
2401.06121	TOFU: A Task of Fictitious Unlearning for LLMs	망각 평가의 사실상 표준 벤치마크

ID	제목	이 프로젝트에서의 용도
2407.06460	MUSE: Machine Unlearning Six-Way Evaluation for Language Models	망각을 6개 속성(축자암기·지식암기·프라이버시 누출·효용보존·확장성·지속성)으로 분해. 리포트 평가측 설계에 직접 차용 가능
2310.07579	In-Context Unlearning: Language Models as Few-Shot Unlearners (Pawelczyk, Neel, Lakkaraju — ICML 2024)	파라미터 수정 없이 컨텍스트만으로 망각. 스킴 레이어에서 가능한 유일한 방향
2402.00751	Fast Exact Unlearning for In-Context Learning Data for LLMs	ICL 데이터에 대한 정확(exact) 망각. 근사가 아닌 보장이 필요할 때
2510.17620	Forget to Know, Remember to Use: Context-Aware Unlearning for LLMs	지식은 잊되 주어진다면 쓸 수 있게 — 업무 효용 손실 최소화
2605.27138	ICCU: In-Context Continual Unlearning via Pattern-Induced Refusal Rules	반복적·연속적 망각 요청 처리
2510.25117	A Survey on Unlearning in Large Language Models	최신 서베이
2209.02299	A Survey of Machine Unlearning (ACM TIST 2025)	전통 ML 포함 총괄

9.3 망각 검증·감사 — Hallucination 금지 요구의 근거

ID	제목	이 프로젝트에서의 용도
2506.15115	Towards Reliable Forgetting: A Survey on Machine Unlearning Verification	검증 방법론 총정리. 필독
2210.11334	Proof of Unlearning: Definitions and Instantiation	“삭제 증명”의 형식적 정의
2003.04247	Towards Probabilistic Verification of Machine Unlearning	확률적 검증의 한계
2602.14553	Governing AI Forgetting: Auditing for Machine Unlearning Compliance	인증 이론과 규제 집행 사이의 간극
2606.16110	Auditing Machine Unlearning: Whether Models Truly Forget	모델이 실제로 잊는지 감사
2506.06112	Lifecycle Unlearning Commitment Management: Sample-level Unlearning Completeness	샘플 단위 완전성 측정

9.4 RAG·메모리 삭제 전파 — 층위 C의 핵심 근거

ID	제목	이 프로젝트에서의 용도
2410.15267	When Machine Unlearning Meets RAG: Keep Secret or Forget Knowledge?	RAG 환경에서의 망각
SIGIR 2026	Deletion Isn't Enough: Auditing RAG for Selective Forgetting	삭제만으로 부족. 검색·인용 아티팩트 잔존 여부를 감사 문제로 정식화. VERIFY 단계 설계의 직접 근거
2605.28732	Tracing and Attributing Errors in LLM Memory Systems	메모리 생성·갱신·삭제 연산의 사후 추적

9.5 정보흐름 추적 / Taint

ID	제목	이 프로젝트에서의 용도
2503.18813	CaMeL: Defeating Prompt Injections by Design (Google DeepMind / ETH)	제어흐름과 데이터흐름 분리. 신뢰 경계 설계의 레퍼런스
2603.22868	Agent-Sentry: Bounding LLM Agents via Execution Provenance	구조적 분류기 + 결정론적 allowlist + LLM 판사 3층. 결정론 우선 + LLM 보조 구조의 실제 사례
2606.04990	From Agent Traces to Trust: A Survey of Evidence Tracing and Execution Provenance	이 분야 서베이. 출발점
2606.05679	Data Flow Control: Data Safety Policies for AI Agents	에이전트용 데이터 안전 정책
2607.24625	APPA: Recoverable Information-Flow Control for Real-World LLM Agents	복구 가능한 IFC — 차단 후 되돌리기
2607.00440	Minos: Multi-Agent Collaborative Framework for Provenance-Based Backward Tracking	REVERSE TRACE의 직접 실행 . 멀티에이전트 역추적

9.6 Contextual Integrity — Axis 기반 판단의 이론적 정당화

ID	제목	이 프로젝트에서의 용도
Nissenbaum 2004	Privacy as Contextual Integrity	이론적 원점. “정보 흐름이 그 맥락의 규범에 부합하는가”
2502.17041	PrivaCI-Bench: Evaluating Privacy with Contextual Integrity and Legal Compliance	법규 준수 결합 벤치마크
2506.04245	Contextual Integrity in LLMs via Reasoning and Reinforcement Learning	추론·RL로 CI 강화
2505.14585	Context Reasoner: Contextualized Privacy and Safety Compliance via RL	맥락화된 컴플라이언스
2606.04067	Need to Know: CI-Grounded Query Rewriting for Privacy-Conscious LLM Delegation	차단 대신 재작성 — 업무 중단 없이 보호. 층위 A 대안으로 검토 가치
2606.21710	PrivacyAlign: Contextual Privacy Alignment for LLM Agents	—

9.7 희석·새니타이즈의 한계 — 기각 근거

ID	제목	이 프로젝트에서의 용도
2609.04382	Privacy Failure in Split-LLM Training: The Returned Gradient Nullifies the Decoys	디코이 방어의 실증 붕괴 사례 . 그래디언트 0 패턴으로 실제 행 전량 식별 (논문 보고값: 9시드, 프레임당 4,096/4,096)

ID	제목	이 프로젝트에서의 용도
2508.18976	The Double-edged Sword of LLM-based Data Reconstruction: Contextual Vulnerability in Word-level DP Text Sanitization	마스킹해도 주변 문맥으로 원문 복원 가능. “레디션했으니 안전”이 왜 hallucination인지의 근거
CCS 2013	Honeywords: Making Password-Cracking Detectable (Juels & Rivest)	디코이 flatness 문제의 원전. 10년 넘게 미해결이라 주요 인증 플랫폼에 미채택
2403.03329	Guardrail Baselines for Unlearning in LLMs (Thaker et al., 2024-03)	단순 가드레일이 파인튜닝 언러닝과 대응. SUPPRESS 채택의 보강 근거
2509.25973	CURE: Scalable and Robust LLM Unlearning by Correcting Responses with Retrieved Exclusions	SUPPRESS 단계의 채택 방식. 출력 검증 후 재작성, 검색 기반 in-context 제외

10

미결 사항과 다음 단계

#	결정해야 할 것	권고
1	층위 A(사전 차단) 포함 범위	최소 혹만 . 전면 구현은 기존 스킴·상용 제품과 정면 충돌
2	Security Axis 등급 체계	회사 실제 등급을 쓰지, 일반 4단계 + canaries 초안으로 갈지

구현 순서

복붙용 프롬프트는 저장소의 PROMPTS.md 에 P0-P10으로 정리되어 있다. P0(공통 규칙)을 매 프롬프트 앞에 붙여 쓴다.

P0	공통 규칙	매 프롬프트 앞에 붙임
P1	스킬 골격	SKILL.md + 디렉터리
P2	Security Axis 스키마	axis/security-axis.yaml
P3	1차 판정기	scripts/classify.py ← LLM 호출 없음
P4	양방향 추적	scripts/trace.py
P5	폐기와 검증	scripts/purge.py, verify.py
P6	카나리	scripts/canary.py
P7	출력측 억제	SUPPRESS 단계
P8	리포트 스키마	references/report-schema.md
P9	자체 검증	테스트 + 금지표현 grep
P10	플러그인 포장	배포 단위 (선택)

검증되지 않은 항목 — 구현 시 반드시 확인할 것

- ① 세션 전사·메모리 파일·툴 로그의 **실제 파일 경로**. 추측해서 하드코딩하지 말 것
- ② 플러그인 매니페스트 규격 — 2차 출처로만 확인했다. 공식 문서 기준으로 재확인
- ③ 혹은 차단 동작과 exit code 규약 — 2차 출처로만 확인했다. 공식 문서 기준으로 재확인
- ④ Messages API의 logit_bias 지원 여부 — 문서에서 기재 **찾지 못했**을 뿐, 부재를 확인한 것이 아니다
- ⑤ 9절 논문 전체 — 제목·ID·보고 수치만 확인. 인용 전 원문 확인 필요